

MARCO INTEGRATIVO GQM + PRAGMATIC APLICADO A LOS INDICADORES DREAD

Trazabilidad desde Objetivos Nacionales de Ciberseguridad hasta Datos Técnicos

Dimensiones D-R-E-A-D · Edición 2025-2026 · España y contexto internacional

"Una métrica sin objetivo es un número buscando desesperadamente un propósito. Un objetivo sin métrica es un deseo con carné de identidad. El GQM les presenta formalmente."

1. FUNDAMENTOS METODOLÓGICOS DEL MARCO INTEGRATIVO

1.1 La metodología GQM

La metodología **GQM (Goal-Question-Metric)**, desarrollada por Basili, Caldiera y Rombach (1994) y adoptada explícitamente por INCIBE en su Marco de Indicadores de Ciberresiliencia (IMC-CII), organiza la medición en tres capas jerárquicas:

NIVEL 1 – META (Goal)

- Propósito: ¿Por qué necesitamos esta información?
- Objeto: ¿Qué estamos midiendo?
- Punto de vista: ¿Desde qué perspectiva?
- Contexto: ¿En qué entorno organizativo/nacional?

NIVEL 2 – PREGUNTA (Question)

- Refina y articula la meta
- Define los aspectos que deben observarse
- Establece los criterios de éxito

NIVEL 3 – MÉTRICA (Metric)

- Dato cuantitativo que responde a la pregunta
- Fuente de datos, fórmula y frecuencia
- Umbral de referencia (objetivo, alerta, crítico)

La aportación de Calvo y Beltrán (Emerald Information & Computer Security, 2024) extiende el GQM clásico hacia un modelo **dinámico** que actualiza métricas conforme evolucionan el entorno de amenazas y los objetivos organizativos — clave en 2025-2026 ante la explosión de ataques impulsados por IA generativa.

1.2 El método PRAGMATIC

El método **PRAGMATIC** (Brotby y Hinson, CRC Press, 2013) evalúa la calidad de las métricas de seguridad mediante nueve criterios:

Criterio	Inglés	Definición para ciberseguridad
P	Predictive	¿Predice comportamientos futuros? ¿Permite anticipar incidentes?
R	Relevant	¿Es relevante para los objetivos de seguridad de la organización?
A	Actionable	¿Genera decisiones concretas? ¿Qué hace el responsable con este número?
G	Genuine	¿El dato es real, no manipulable ni fabricado?
M	Meaningful	¿Lo entienden los distintos stakeholders (técnicos y directivos)?
A	Accurate	¿Mide exactamente lo que pretende, con la precisión necesaria?
T	Timely	¿Está disponible cuando se necesita para tomar decisiones?
I	Independent	¿Es independiente para evitar redundancias o correlaciones espurias?
C	Cheap	¿El coste de obtención es proporcional al valor que aporta?

Escala de puntuación PRAGMATIC: Cada criterio se puntúa de 0 a 10. Total: 0–90.

- >= 72 (80%+): Métrica de élite — adoptar sin reservas
- 63–71 (70–79%): Alta calidad — adoptar con monitorización
- 45–62 (50–69%): Calidad media — adoptar con mejoras específicas
- < 45 (<50%): Baja calidad — revisar o descartar

1.3 Integración QGM + PRAGMATIC para DREAD

Cuatro pasos del marco integrativo:

1. Anclar cada dimensión DREAD a metas nacionales (ENC 2019-2025, LCGC/CNCS 2025, NIS2, ENS, DORA)
2. Descomponer cada meta en preguntas QGM que articulan qué hay que saber para verificar si se alcanza la meta
3. Asignar métricas cuantitativas a cada pregunta, con fórmula, fuente, frecuencia y umbrales
4. Calificar cada métrica bajo los nueve criterios PRAGMATIC (0-10 c/u) → véase Documento B

2. OBJETIVOS NACIONALES DE REFERENCIA (Metas de Nivel 0)

Código	Objetivo nacional	Fuente normativa
ON-1	Reducir el impacto de los ciberincidentes en la economía y la sociedad española	ENC 2019-2025, LA-1
ON-2	Mejorar la detección y respuesta ante ciberamenazas en sectores esenciales	ENC LA-2; NIS2 Art.21; LCGC-2025
ON-3	Fortalecer la resiliencia de las infraestructuras críticas nacionales	PIC/LPIC; NIS2 Art.21.2.c; ENS Alta
ON-4	Proteger los derechos fundamentales de los ciudadanos en el espacio digital	ENC LA-4; GDPR; LOPDGDD; NIS2 Art.23
ON-5	Desarrollar cultura de ciberseguridad y capacidades nacionales	ENC LA-7; INCIBE-IMC; NIS2 Art.21.2.g
ON-6	Alinear España con marcos normativos europeos (NIS2, DORA, CRA)	LCGC-2025 Art.1; CNCS; DORA Art.5

3. ÁRBOL GQM + MÉTRICAS POR DIMENSIÓN DREAD

3.1 DIMENSIÓN D — DAÑO (Damage Potential)

"La pregunta más honesta en ciberseguridad: ¿cuánto duele? La dificultad no es técnica, sino la voluntad de mirar la herida de frente."

META D.G1: Minimizar el impacto de los ciberincidentes en activos críticos, de modo que el daño no supere el umbral de "incidente significativo" (NIS2 Art.23) y que el ALE se mantenga dentro del apetito de riesgo aprobado por el Consejo.

- Propósito: Minimizar | Objeto: Impacto económico, operativo, reputacional y sobre vidas humanas
- Punto de vista: CISO, Consejo, CNCS, Regulador sectorial | Objetivos ancla: ON-1, ON-3, ON-6

D.M1 — ALE por amenaza crítica (Annualized Loss Expectancy)

- Pregunta D.Q1: ¿Cuál es la pérdida financiera esperada si se materializa la amenaza de mayor DREAD-D?
- Fórmula: $ALE = ARO \times SLE$ (frecuencia_anual $\times$ coste_medio_incidente_€)
- Fuente: CMDB + registros incidentes + benchmark INCIBE 2025 | Unidad: €/año | Frecuencia: Trimestral
- Umbrales: Objetivo < 1% facturación; Alerta 1–5%; Crítico > 5%
- Norma: NIS2 Art.21.2; DORA Art.6; FAIR Institute | Puntuación PRAGMATIC: **70/90** — ALTA

D.M2 — Índice de Exposición de Activos Críticos (IEAC)

- Pregunta D.Q2: ¿Qué proporción de activos críticos quedarían comprometidos?

- Fórmula: $IEAC = (N_{\text{activos_críticos_expuestos}} / N_{\text{total_activos_críticos}}) \times 100$
- Fuente: CMDDB + análisis blast radius | Unidad: % | Frecuencia: Mensual
- Umbrales: Objetivo < 10%; Alerta 10–30%; Crítico > 30%
- Norma: ENS Medida 2; NIS2 Art.21.2.f; ISO27001 A.8.1 | Puntuación PRAGMATIC: **62/90** — MEDIA

D.M3 — RTO realista vs. RTO objetivo (RTO gap)

- Pregunta D.Q3: ¿Cuál es el tiempo de indisponibilidad potencial ante un incidente de daño máximo?
- Fórmula: $RTO_{\text{gap}} = RTO_{\text{estimado_simulación}} - RTO_{\text{objetivo}} \text{ (horas)}$
- Fuente: Ejercicios BCP/DRP | Unidad: Horas | Frecuencia: Semestral
- Umbrales: Objetivo gap ≤ 0; Alerta 0–4h; Crítico > 4h para servicios esenciales
- Norma: DORA Art.11; NIS2 Art.21.2.c | Puntuación PRAGMATIC: **72/90** — ÉLITE

D.M4 — Tasa de Brechas con Notificación Obligatoria (TBNO)

- Pregunta D.Q4: ¿Qué proporción de incidentes generan daño a datos personales notificable a la AEPD?
- Fórmula: $TBNO = (N_{\text{incidentes_con_datos_personales}} / N_{\text{incidentes_totales}}) \times 100$
- Fuente: Registro DPO + SIEM | Unidad: % | Frecuencia: Mensual
- Norma: GDPR Arts.33-34; LOPDGDD | Puntuación PRAGMATIC: **62/90** — MEDIA

D.M5 — Tiempo medio de clasificación DREAD-D (TMCD)

- Pregunta D.Q5: ¿Con qué rapidez se clasifica el nivel de daño de una nueva amenaza identificada?
- Fórmula: $TMCD = \Sigma(\text{tiempo_clasificación_i}) / N_{\text{amenazas_nuevas}} \text{ (horas)}$
- Fuente: ITSM/ticketing | Unidad: Horas | Frecuencia: Mensual
- Umbrales: Objetivo < 4h para críticas; Crítico > 24h
- Norma: NIS2 Art.23; ENISA ETL Methodology | Puntuación PRAGMATIC: **73/90** — ÉLITE

3.2 DIMENSIÓN R — REPRODUCIBILIDAD (Reproducibility)

"Si un ataque puede repetirse tan fácilmente como reproducir una canción en streaming, el problema deja de ser técnico y pasa a ser estadístico."

META R.G1: Reducir la reproducibilidad efectiva de ataques de modo que el tiempo entre publicación de exploit y explotación real supere los plazos de parcheo definidos en los SLAs de gestión de vulnerabilidades.

- Propósito: Reducir | Objeto: Probabilidad de reproducción efectiva de ataques
- Objetivos nacionales ancla: ON-2, ON-3

R.M1 — MTTR por criticidad DREAD-R (Mean Time To Remediate estratificado)

- Pregunta R.Q1: ¿Cuánto tiempo entre publicación de CVE con exploit público y parcheo del sistema?
- Fórmula: $MTTR_R = \Sigma(\text{fecha_parche} - \text{fecha_CVE_publicado}) / N_{\text{CVEs_por_nivel_R}}$
- Fuente: VM tool + NVD/NIST + feeds INCIBE-CERT | Unidad: Días | Frecuencia: Mensual
- Umbrales: ≤ 7 días para R=10; ≤ 30 días para R=7-9; Crítico > 30 días para R=10
- Norma: ENS Med.5; CRA Art.13; NIS2 Art.21.2.e | Puntuación PRAGMATIC: **77/90** — ÉLITE

R.M2 — Tasa de Vulnerabilidades EPSS-alto sin Remediar (TVER)

- Pregunta R.Q2: ¿Qué % de vulnerabilidades con EPSS > 0.5 están sin parchear?

- Fórmula: $TVER = (N_CVEs_EPSS \geq 0.5_sin_parche / N_CVEs_EPSS \geq 0.5_totales) \times 100$
- Fuente: FIRST EPSS API (gratuita) + escáner VM | Unidad: % | Frecuencia: Semanal (críticos) / Mensual
- Umbrales: Objetivo < 5%; Alerta 5–20%; Crítico > 20%
- Nota científica: EPSS AUPRC 0.365 vs CVSS 0.011 — 33× más predictivo (Arxiv 2025)
- Norma: NIS2 Art.21.2.e | Puntuación PRAGMATIC: **78/90** — ÉLITE MÁXIMA

R.M3 — Índice de Cobertura de Exploits Públicos (ICEP)

- Pregunta R.Q3: ¿Cuántas amenazas del registro DREAD tienen exploit funcional en bases públicas?
- Fórmula: $ICEP = (N_amenazas_con_exploit_público / N_amenazas_registradas) \times 100$
- Fuente: ExploitDB + Metasploit + VulDB + NVD | Unidad: % | Frecuencia: Mensual
- Puntuación PRAGMATIC: **63/90** — ALTA

R.M4 — Ventana de Exposición a Exploit (VEE)

- Pregunta R.Q4: ¿Tiempo medio de exposición de sistemas críticos con $R \geq 8$ desde publicación del CVE?
- Fórmula: $VEE = fecha_detección_interna - fecha_publicación_CVE$ (días)
- Fuente: VM tool + NVD + SIEM timeline | Unidad: Días | Umbral: < 1 día para activos Tier-1
- Puntuación PRAGMATIC: **74/90** — ÉLITE

3.3 DIMENSIÓN E — EXPLOTABILIDAD (Exploitability)

"La explotabilidad en 2025 ya no requiere doctorado. Requiere acceso a internet, 20 dólares en una plataforma de IA y tiempo libre. Que el adversario tiene."

META E.G1: Aumentar el coste de ataque (cost-to-exploit) por encima del beneficio esperado por el atacante, incluso considerando la democratización del ataque por IA generativa.

- Propósito: Aumentar | Objeto: Dificultad técnica y operacional de explotar vulnerabilidades
- Objetivos nacionales ancla: ON-2, ON-5

E.M1 — Score medio de explotabilidad CVSS v4.0 (SMEC)

- Pregunta E.Q1: ¿Puntuación media de explotabilidad de vulnerabilidades activas según CVSS v4.0?
- Fórmula: $SMEC = \sum(CVSS_Exploitability_subscore_i) / N_CVEs_activos$
- Fuente: NVD CVSS v4.0 API | Escala: 0–10 | Frecuencia: Semanal
- Umbrales: Objetivo < 5.0; Crítico > 7.5 | Puntuación PRAGMATIC: **66/90** — ALTA

E.M2 — Tasa de Coincidencia con CISA KEV (TCKEV) ★ MÉTRICA #1 DEL KIT

- Pregunta E.Q2: ¿Qué % de vulnerabilidades activas figuran en el catálogo CISA KEV?
- Fórmula: $TCKEV = (N_CVEs_en_KEV \cap N_CVEs_activos) / N_CVEs_activos \times 100$
- Fuente: CISA KEV catalog API (gratuita, actualización diaria) + inventario VM | Frecuencia: Diaria
- Umbrales: Objetivo 0%; Crítico > 2% en infraestructura crítica
- Nota: Combinar CVSS + EPSS + KEV reduce carga de priorización ~95% (KCYERRID, 2026)
- Puntuación PRAGMATIC: **85/90** — ÉLITE ABSOLUTA

E.M3 — Score DREAD-E para ataques sobre IA/LLMs

- Pregunta E.Q3: ¿Explotabilidad de ataques sobre sistemas de IA/LLMs propios según DREAD adaptado?

- Fórmula: $E_LLM = \text{media}(\text{prompt_injection_E}, \text{model_extraction_E}, \text{adversarial_E}, \text{data_poisoning_E})$
- Referencia: Zahid et al. (U.Waikato 2025): prompt injection E=9, model extraction E=8
- Umbral crítico: $E_LLM > 7.0$ → controles de IA security obligatorios
- Puntuación PRAGMATIC: **60/90** — MEDIA (emergente; madurez metodológica en desarrollo)

E.M4 — Tiempo medio de contención de explotación (TMCE)

- Pregunta E.Q4: ¿Con qué rapidez se detiene un intento de explotación activa una vez detectado?
- Fórmula: $TMCE = \text{fecha_contención} - \text{fecha_alerta_SIEM} \text{ (horas)}$
- Fuente: SIEM / SOAR timestamps | Umbral: < 1h para Tier-1 | Puntuación PRAGMATIC: **77/90** — ÉLITE

E.M5 — Índice de Cobertura de Controles Anti-Explotación (ICCAE)

- Pregunta E.Q5: ¿Qué % de la superficie de ataque tiene controles activos (MFA, micro-segmentación, PAM)?
- Fórmula: $ICCAE = (\text{N_activos_con_controles} / \text{N_activos_totales}) \times 100$
- Umbrales: $\geq 95\%$ Tier-1; $\geq 80\%$ global | Puntuación PRAGMATIC: **63/90** — ALTA

3.4 DIMENSIÓN A — USUARIOS AFECTADOS (Affected Users)

"Afectar a diez usuarios en una PYME y afectar a diez millones de ciudadanos en una infraestructura crítica comparten el mismo score DREAD si no calibramos la escala. Precisamente ahí reside el reto."

META A.G1: Minimizar los usuarios afectados de modo que los incidentes no superen el umbral de "gran magnitud" (NIS2 Art.23.3) y la organización pueda notificar con exactitud en < 72 horas.

- Propósito: Minimizar | Objeto: Número de usuarios/ciudadanos afectados por ciberincidentes
- Objetivos nacionales ancla: ON-1, ON-4, ON-6

A.M1 — Usuarios Máximos Potencialmente Afectados (UMPA)

- Pregunta A.Q1: ¿Cuántos usuarios quedarían sin servicio ante un incidente en el sistema de mayor DREAD-A?
- Fórmula: $UMPA = \text{N_usuarios_del_servicio_más_crítico}$ (dato del CRM/inventario)
- Umbral crítico NIS2: > 50.000 → probable "gran magnitud" → notificación CNCS obligatoria
- Puntuación PRAGMATIC: **75/90** — ÉLITE

A.M2 — Índice de Usuarios Vulnerables Afectados (IUVA)

- Pregunta A.Q2: ¿Qué % de usuarios afectados corresponde a categorías vulnerables?
- Fórmula: $IUVA = (\text{N_usuarios_vulnerables_afectados} / \text{N_usuarios_totales_afectados}) \times 100$
- Norma: GDPR Arts.9-10 | Puntuación PRAGMATIC: **58/90** — MEDIA

A.M3 — Tiempo medio de notificación a usuarios (TMNU)

- Pregunta A.Q3: ¿Con qué rapidez se notifica a los usuarios afectados tras detectar el incidente?
- Fórmula: $TMNU = \text{fecha_notificación} - \text{fecha_detección} \text{ (horas)}$

- Umbrales: < 72h para notificación AEPD (GDPR Art.33); < 30 días para afectados con alto riesgo
- Puntuación PRAGMATIC: **76/90** — ÉLITE

A.M4 — Coste por Usuario Afectado (CUA)

- Pregunta A.Q4: ¿Impacto financiero medio por usuario afectado?
- Fórmula: $CUA = \text{Coste_total_incidente_€} / N_usuarios_afectados$
- Benchmark: ~186 €/registro comprometido (IBM/Ponemon, media UE 2025)
- Puntuación PRAGMATIC: **57/90** — MEDIA

A.M5 — Cobertura de Continuidad para Usuarios Críticos (CCUC)

- Pregunta A.Q5: ¿Qué % de usuarios está cubierto por BCP/DRP con garantía de continuidad?
- Fórmula: $CCUC = (N_usuarios_bajo_BCP / N_usuarios_totales) \times 100$
- Umbrales: $\geq 99\%$ esenciales NIS2; $\geq 80\%$ resto | Puntuación PRAGMATIC: **67/90** — ALTA

3.5 DIMENSIÓN Disc — DESCUBRIBILIDAD (Discoverability)

"La seguridad por oscuridad es como esconder las llaves bajo el felpudo: funciona hasta que alguien mira. Y los atacantes de 2025 usan Shodan, IA y tiempo libre. Siempre miran."

META Disc.G1: Reducir la descubribilidad real de vulnerabilidades por actores externos, priorizando la reducción activa de la superficie de ataque sobre la dependencia de la oscuridad.

- Propósito: Reducir | Objeto: Descubribilidad de vulnerabilidades por actores externos
- Objetivos nacionales ancla: ON-2, ON-3

Disc.M1 — Ratio de Superficie de Ataque Expuesta (RSAE)

- Pregunta Disc.Q1: ¿Qué % de activos es visible externamente sin autenticación previa?
- Fórmula: $RSAE = (N_activos_visibles_internet / N_activos_inventariados) \times 100$
- Fuente: ASM tools (Shodan, Censys, EASM) | Frecuencia: Semanal
- Umbrales: Objetivo < 5% activos no intencionalmente públicos; Alerta > 15%
- Puntuación PRAGMATIC: **78/90** — ÉLITE MÁXIMA

Disc.M2 — Ratio de Detección Proactiva vs. Reactiva (RDPR)

- Pregunta Disc.Q2: ¿Con qué frecuencia la organización descubre sus vulnerabilidades antes que el atacante?
- Fórmula: $RDPR = (N_vulns_descubiertas_internamente / N_vulns_totales) \times 100$
- Umbrales: Objetivo $\geq 80\%$; Crítico < 50% (el atacante tiene ventaja sistemática)
- Puntuación PRAGMATIC: **67/90** — ALTA

Disc.M3 — Número de Servicios Innecesarios Expuestos (NSIE)

- Pregunta Disc.Q3: ¿Cuántos puertos/servicios innecesarios permanecen abiertos tras el último hardening?
- Fórmula: $NSIE = N_puertos_activos_no_justificados$
- Umbrales: Objetivo = 0 en Tier-1; Crítico > 10 en activo crítico
- Puntuación PRAGMATIC: **70/90** — ALTA

Disc.M4 — Tiempo Medio de Detección Externa (TMDE)

- Pregunta Disc.Q4: ¿Tiempo entre que una vulnerabilidad es explotable externamente y la organización la detecta?
- Fórmula: $TMDE = fecha_detección_interna - fecha_aparición_Shodan/CVE$ (días)
- Umbrales: < 1 día Tier-1; Crítico > 7 días | Puntuación PRAGMATIC: **71/90** — ALTA

4. TABLA MAESTRA DE TRAZABILIDAD GQM

Objetivo Nacional	Dim. DREAD	ID Métrica	Nombre Métrica	Score PRAGMAT IC	Nivel	Umbral Crítico	Norma Principal
ON-1	D	D.M1	ALE por amenaza crítica	70	ALTA	> 5% facturación	DORA Art.6
ON-1, ON-3	D	D.M2	IEAC	62	MEDIA	> 30% activos críticos	NIS2 Art.21.2.f
ON-3	D	D.M3	RTO gap	72	ÉLITE	> 4h en esenciales	DORA Art.11
ON-4	D	D.M4	TBNO	62	MEDIA	Tendencia creciente	GDPR Art.33
ON-2	D	D.M5	TMCD	73	ÉLITE	> 24h	NIS2 Art.23
ON-2, ON-3	R	R.M1	MTTR por DREAD-R	77	ÉLITE	> 30 días para R=10	ENS Med.5; CRA
ON-2	R	R.M2	TVER (EPSS-alto)	78	ÉLITE	> 20% sin parche	NIS2 Art.21.2.e
ON-3	R	R.M3	ICEP	63	ALTA	Tendencia creciente	NVD/ NIST
ON-2	R	R.M4	VEE	74	ÉLITE	> 7 días Tier-1	CRA Art.13
ON-2, ON-5	E	E.M1	SMEC CVSS v4.0	66	ALTA	> 7.5	NIS2 Art.21
ON-2	E	E.M2	TCKEV (CISA KEV)	85	ÉLITE ABSOLUTA	> 2% en IC	CISA KEV; ENS
ON-5	E	E.M3	DREAD-ELLMs	60	MEDIA	> 7.0	OWASP LLM Top 10
ON-2	E	E.M4	TMCE	77	ÉLITE	> 1h Tier-1	DORA Art.19
ON-5	E	E.M5	ICCAE	63	ALTA	< 80% global	NIS2 Art.21.2.g
ON-4, ON-1	A	A.M1	UMPA	75	ÉLITE	> 50.000 usuarios	NIS2 Art.23.3
ON-4	A	A.M2	IUVA	58	MEDIA	Tendencia creciente	GDPR Art.9-10
ON-4, ON-6	A	A.M3	TMNU	76	ÉLITE	> 72h notif. AEPD	GDPR Art.33

ON-1	A	A.M4	CUA	57	MEDIA	> 186 €/usuario	FAIR; Ponemon 2025
ON-3, ON-4	A	A.M5	CCUC	67	ALTA	< 99% esenciales	NIS2; DORA Art.11
ON-3	Disc	Disc.M1	RSAE	78	ÉLITE	> 15% expuesto	CRA Art.13
ON-2	Disc	Disc.M2	RDPR	67	ALTA	< 50% proactivo	NIS2 Art.21.2.h
ON-3	Disc	Disc.M3	NSIE	70	ALTA	> 10 en críticos	ENS; CRA
ON-2, ON-3	Disc	Disc.M4	TMDE	71	ALTA	> 7 días	NIS2; NIST CSF

Marco GQM+PRAGMATIC · Documento A del Kit DREAD · Abril 2026

GQM: Basili et al. (1994); INCIBE-IMC (2023); Calvo & Beltrán, Emerald (2024)

PRAGMATIC: Brothby & Hinson (2013), CRC Press/Taylor & Francis